

Hardening de Correo Corporativo en Microsoft 365: Guía Técnica con EOP y Defender

Caso real de configuración avanzada con licenciamiento estándar y recomendaciones para entornos con Defender P1/P2.

Autor: SYSARMOR TECH

Enfoque: Infraestructura, Seguridad de la Información, Operación e Innovación

Introducción

El correo electrónico continúa siendo el principal vector de ataque en entornos corporativos, utilizado para distribuir ransomware, ejecutar fraudes de tipo Business Email Compromise (BEC) y realizar robo de credenciales mediante técnicas de suplantación sofisticadas. Aunque Exchange Online Protection (EOP) ofrece un nivel básico de filtrado, su cobertura resulta limitada frente a amenazas evasivas y ataques de identidad avanzados.

Este manual presenta la línea base de endurecimiento técnico (Hardening Baseline) recomendada para fortalecer la seguridad del correo corporativo en Microsoft 365, estructurada en dos niveles operativos:

1. Configuración Nivel 2 – EOP: Protección estándar incluida en los licenciamientos básicos, basada en controles nativos de firma, reputación y alineación de identidad mediante DMARC.
2. Capítulo Nivel 3 – Defender Plan 1/P2: Extensión avanzada con inteligencia artificial, análisis en sandbox y verificación *time-of-click* para mitigar amenazas de día cero.

Requisitos Previos y Alineación de Identidad

- ✓ Permisos requeridos: Rol de Security Administrator en el portal de seguridad (security.microsoft.com) u Organization Management en Exchange Online.
- ✓ Prerrequisito Técnico Obligatorio: Registros SPF, DKIM y DMARC (con política mínima p=quarantine o p=reject) correctamente publicados en el DNS público del dominio corporativo.

Nota técnica: Microsoft defender es una solución XDR (Detección y Respuesta Extendida, plataforma unificada de ciberseguridad que recopila y correlaciona datos automáticamente de múltiples capas de seguridad), para la elaboración de este manual solamente nos vamos a enfocar en la solución de Microsoft defender para Office 365 que es la parte de colaboración y correo electrónico, donde vamos a identificar, cómo configurar directivas como: Directivas de seguridad predeterminadas, Directiva anti phishing, Directiva antispam, Directiva antimalware, Directiva de cuarentena y Listas de bloqueados.

Las directivas de Microsoft Defender para correo electrónico, son reglas de seguridad que protegen contra amenazas como *phishing*, *malware* y correo no deseado. Se administran desde el Portal de Microsoft Defender en la sección de *Directivas y reglas*.

security.microsoft.com > Email & collaboration > Policies & rules > Threat policies>

Protección contra phishing

De forma predeterminada, Microsoft 365 incluye características integradas que ayudan a proteger a los usuarios de ataques de phishing. Configure directivas de protección contra suplantación de identidad (anti-phishing) para aumentar esta protección. Por ejemplo, puede refinar la configuración para detectar y prevenir mejor los ataques de suplantación de identidad y suplantación electrónica. La directiva predeterminada se aplica a todos los usuarios dentro de la organización. Puede crear directivas personalizadas de mayor prioridad para usuarios, grupos o dominios específicos. [Más información sobre las directivas de protección contra suplantación de identidad \(anti-phishing\)](#)

Se recomienda habilitar las directivas de seguridad preestablecidas para mantenerse al día con los nuevos controles de seguridad y la configuración recomendada. [Ver directivas de seguridad preestablecidas](#)

+ Crear Exportar Actualizar		1 elemento	Buscar	Filtrar
☐ Nombre	Estado	Prioridad	Última modificación	
☐ Office365 AntiPhish Default (predeterminado)	● Siempre activada	La más baja	5 de ago. de 2026	

Directivas de correo electrónico no deseado

Se recomienda habilitar las directivas de seguridad preestablecidas para mantenerse al día con los nuevos controles de seguridad y la configuración recomendada. [Ver directivas de seguridad preestablecidas](#)

Utilice esta página para configurar directivas que se incluyen en la protección contra correo no deseado. Estas directivas incluyen el filtrado de conexión, el de correo no deseado y el de correo no deseado de salida. [Más información](#)

+ Crear directiva Actualizar		3 elementos	Buscar
☐ Nombre	Estado	Prioridad	Tipo
☐ Directiva de entrada de correo no deseado (predeterminado)	● Siempre activada	La más baja	
☐ Directiva de filtro de conexión (predeterminado)	● Siempre activada	La más baja	
☐ Directiva de salida de correo electrónico no deseado (predeterminado)	● Siempre activada	La más baja	

Protección antimalware

Se recomienda habilitar las directivas de seguridad preestablecidas para mantenerse al día con los nuevos controles de seguridad y la configuración recomendada. [Ver directivas de seguridad preestablecidas](#)

+ Crear Exportar Actualizar		1 elemento	Buscar
☐ Nombre	Estado	Prioridad	
☐ Default (predeterminado)	● Siempre activada	La más baja	

Tipos de Directivas Principales

- Antispam: Bloquea o pone en cuarentena mensajes de correo no deseado tanto entrantes como salientes.
- Antimalware: Detecta y bloquea archivos o códigos maliciosos en los mensajes adjuntos.
- Antisuplantación (*Anti-phishing*): Protege contra ataques de suplantación de identidad (*spoofing*) y fraudes de tipo CEO

PARTE 1: Hardening con Licenciamiento Estándar (EOP)

Fase 1: Política Anti-Phishing por Defecto (Office365 AntiPhish Default)

Ubicación en portal: security.microsoft.com > Email & collaboration > Policies & rules > Threat policies > Anti-phishing

Abre la política predeterminada, haz clic en Editar acciones (Edit actions) y aplica los siguientes ajustes:

- Acción para Spoofing (Inteligencia de suplantación):
 - Valor por defecto: Mover a la carpeta Correo no deseado.
 - Ajuste SysArmor: Poner en cuarentena el mensaje (DefaultFullAccessPolicy). Evita que el usuario interactúe con el correo.
- Primer consejo de seguridad de contacto (First contact safety tip): Activado.
 - Muestra una advertencia visual si es la primera vez que se recibe un mensaje desde esa dirección.
- Símbolo de remitente no autenticado (?): Activado.
- Mostrar etiqueta "vía": Activado.
- Respetar directiva DMARC (p=quarantine / p=reject): Activado.

Editar acciones

- ☒ Respetar la directiva de registro DMARC cuando se detecte el mensaje como suplantación de identidad

Si el mensaje se detecta como suplantación de identidad y la directiva DMARC se establece como p=quarantine

Poner en cuarentena el mensaje

Pondremos el mensaje en cuarentena para que lo revise y decida si debe ser liberado.
[Información sobre cómo administrar mensajes en cuarentena](#)

Si el mensaje se detecta como suplantación de identidad y la directiva DMARC se establece como p=reject

Poner en cuarentena el mensaje

Pondremos el mensaje en cuarentena para que lo revise y decida si debe ser liberado.
[Información sobre cómo administrar mensajes en cuarentena](#)

Si el mensaje se detecta como suplantación de identidad por la inteligencia de suplantación de identidad

Mover el mensaje a las carpetas Correo no deseado de los d...

Mover el mensaje a las carpetas Correo no deseado de los destinatarios

Sugerencias e indicadores de seguridad ⓘ

- ☒ Mostrar la sugerencia de seguridad del primer contacto (recomendado) ⓘ
- ☒ Mostrar (?) para los remitentes no autenticados para la suplantación ⓘ
- ☒ Mostrar la etiqueta "vía". ⓘ

Guardar

Cancelar

Configuración vía PowerShell (Exchange Online)

Connect-ExchangeOnline

Ajustar acción de Spoofing a Cuarentena

```
Set-AntiPhishPolicy -Identity "Office365 AntiPhish Default" -SpoofProtectionAction Quarantine -EnableFirstContactSafetyTips $true -EnableUnauthenticatedSender $true -EnableViaTag $true
```

Fase 2: Políticas Anti-Spam y Purga ZAP

Ubicación en portal: security.microsoft.com > Email & collaboration > Policies & rules > Threat policies > Anti-spam

1. Editar Anti-spam inbound policy (Default):

- Spam & High Confidence Spam: Mover a correo no deseado o poner en cuarentena.
- Phishing: Poner en cuarentena el mensaje.
- High Confidence Phishing: Poner en cuarentena (Retención de 30 días).

Acciones

Acciones en mensajes

Correo no deseado

Mover el mensaje a la carpeta Correo electrónico no deseado



Correo no deseado de confianza alta

Mover el mensaje a la carpeta Correo electrónico no deseado



Phishing

Mensaje en cuarentena



Seleccionar directiva de cuarentena

DefaultFullAccessPolicy



Suplantación de identidad de alta confianza

Mensaje en cuarentena



Se omitirá el permiso para liberar mensajes en cuarentena para los mensajes detectados como phishing de alta confianza. El permiso revertirá a la solicitud de liberación en su lugar.

Seleccionar directiva de cuarentena

AdminOnlyAccessPolicy



2. Verificar ZAP (Zero-Hour Auto Purge):

- Asegurar que Spam ZAP y Phish ZAP estén marcados como Habilitados. ZAP elimina automáticamente correos del buzón si Microsoft actualiza su reputación *después* de la entrega.

Mensajes dentro de la organización sobre los que tomar medidas

Predeterminado

Conservar el spam en cuarentena durante esta cantidad de días

30

Agregar este texto de encabezado X

Anteponer la línea de asunto con este texto

Redirigir a esta dirección de correo electrónico

Sugerencias de seguridad

☒ Habilitar sugerencias de seguridad para el spam ⓘ

Purga automática (ZAP)

☒ Habilitar purga automática (ZAP) ⓘ

☒ Habilitar para mensajes de suplantación de identidad (phishing)

☒ Habilitar para mensajes de correo no deseado

Guardar

Cancelar

Fase 3: Anti-Malware y Bloqueo de Extensiones de Riesgo

Ubicación en portal: security.microsoft.com > Email & collaboration > Policies & rules > Threat policies > Anti-malware

1. En la política predeterminada, habilitar el Filtro de tipos de archivos adjuntos comunes.
2. Verificar e incluir las siguientes extensiones bloqueadas de forma estricta: ace, ani, app, docm, exe, iso, jar, js, jse, vbe, vbs, ws, wsf, ps1, bat, cmd, hta, lnk, reg, scr, img

3. Notificaciones: Configurar alerta por correo al equipo técnico (ti-soc@sysarmortech.com) cuando se intercepte malware.

Edite la configuración de protección

Establecer la configuración para esta directiva antimalware

Configuración de protección

- ☒ Habilitar la purga automática contra malware (recomendado) ⓘ
- ☒ Habilitar el filtro de datos adjuntos comunes ⓘ
.ace, .apk, .app, .appx, .ani, .arj, .bat, .cab, .cmd, .com y 43 otros tipos de archivos

[Seleccionar tipos de archivo](#)

Cuando se encuentran estos tipos de archivo

- ☐ Rechazar el mensaje con un informe de no entrega (NDR) ⓘ
- ☒ Poner en cuarentena el mensaje

Directiva de cuarentena

AdminOnlyAccessPolicy

Se omitirá el permiso para liberar mensajes en cuarentena para los mensajes con malware detectado y, en su lugar, revertiremos a la solicitud de liberación.

Notificación

Notificaciones de administrador para remitentes internos

- ☒ Notificar a un administrador sobre mensajes no entregados de remitentes internos

Dirección de correo electrónico del administrador *

ti-soc@sysarmortech.com

Notificaciones de administrador para remitentes externos

- ☒ Notificar a un administrador sobre mensajes no entregados de remitentes externos

Dirección de correo electrónico del administrador *

Guardar

Cancelar

PARTE 2: Capítulo Especial – Capacidades Avanzadas con Defender for Office 365 (Plan 1 / Plan 2)

En esta sección se detallan las funcionalidades adicionales que se desbloquean al adquirir licencias Microsoft Defender for Office 365 Plan 1/P2 (o *Business Premium*). Este cuadro sirve como matriz de justificación técnica ante la gerencia.

1. Anti-Phishing Avanzado (Impersonation Protection)

A diferencia del filtro básico de EOP, el Plan 1/P2 permite:

- User Impersonation: Proteger hasta 350 usuarios clave (CEO, CFO, TI) rastreando variaciones de su nombre completo en el remitente.
- Domain Impersonation: Monitorear dominios propios y de socios para evitar ataques mediante *typosquatting* (ejemplo: sysarmortech.co VS sysarmortech.com).
- Phishing Threshold (Umbral): Ajustar la sensibilidad del motor heurístico IA a 3 - Aggressive.
- Mailbox Intelligence: Permite al sistema aprender los patrones habituales de comunicación entre empleados para detectar desvíos anómalos.

2. Safe Attachments (Análisis en Sandbox)

- Análisis dinámico de archivos de día cero: Cuando llega un adjunto desconocido, EOP solo pasa firmas conocidas. Defender P1 detona el archivo en un entorno virtual (*sandbox*) en la nube de Microsoft antes de entregarlo.
- Dynamic Delivery (Entrega Dinámica): Entrega el cuerpo del correo inmediatamente al usuario mientras procesa el archivo adjunto en segundo plano, evitando retrasos operativos.

3. Safe Links (Inspección Time-of-Click)

- Reescritura de URLs: Reescribe todas las direcciones web entrantes (*.safelinks.protection.outlook.com).
- Inspección al hacer clic: Si un enlace seguro cambia maliciosamente horas después de la entrega, Safe Links evalúa el sitio en tiempo real al momento del clic y bloquea el acceso en Outlook o Microsoft Teams.

4. Herramientas de Investigación (Exclusivo Plan 2)

- Threat Explorer: Panel interactivo para hacer *hunting* de correos, analizar vectores de ataque por IP y realizar borrado masivo de mensajes sospechosos en todos los buzones del tenant.
- Simulador de Ataques (Attack Simulation Training): Ejecución de campañas internas de phishing controlado para evaluar al personal.

5. Tabla comparativa EOP vs Defender

Funcionalidad	EOP (incluido)	Defender P1/P2 (Add-on)
Anti-spam básico	✓	✓
Anti-phishing estándar	✓	✓ (con IA, impersonation)
Bloqueo de adjuntos comunes	✓	✓
Safe Attachments (sandbox)	X	✓
Safe Links (time-of-click)	X	✓
Threat Explorer	X	✓ (Plan 2)
Simulador de ataques	X	✓ (Plan 2)

Fase: Pruebas de Laboratorio (Entorno EOP Actual)

1. Se envió un correo a la cuenta CorreoLAB@SysarmorTech.onmicrosoft.com, con un archivo adjunto .ps1 o .exe.
2. Resultado esperado: El correo es rechazado o enviado a cuarentena por la regla de *Common Attachments Filter*.
3. La otra prueba realizada fue se envió la cuenta CorreoLAB@SysarmorTech.onmicrosoft.com una (cadena EICAR, es un texto estándar e inofensivo de 68 caracteres que se usa de forma segura para comprobar si un programa antivirus detecta y bloquea amenazas correctamente, sin necesidad de arriesgar el equipo con un virus informático), con esto logramos validar la acción del motor Anti-Malware.
4. **Resultado esperado:** El correo fue rechazado y enviado a cuarentena de acuerdo a lo configurado en la directiva, por considerarse malware, adicional se envió un correo de notificación al equipo técnico (ti-soc@sysarmortech.com), informando el evento.



En **SysArmor Tech**, esta guía y su implementación se construyen bajo principios de arquitectura robusta, automatización y seguridad por diseño. Cada laboratorio busca resolver problemáticas complejas de infraestructura de nivel 2 y 3, priorizando el uso de estándares limpios y mantenibles.

Al tratarse de un espacio de divulgación e ingeniería personal, este documento se comparte como un recurso de referencia técnica abierta. Te invito a explorar los demás artículos del sitio, utilizar las herramientas interactivas disponibles y conectar a nivel profesional a través de LinkedIn.